

WESTWILD CTF

Walkthrough Report

Penetration Testing Lab Exercise — Boot2Root Enumeration & Exploitation

Target Machine	WestWild (boot2root VM)
Target IP Address	192.168.190.131
Attacking Platform	Kali Linux 2026.1 (VMware Workstation)
Network Mode	Host-only / isolated lab segment
Date of Engagement	June 27, 2026
Performed By	Likhith

1. Objective

This report documents a hands-on walkthrough of the WestWild boot2root virtual machine, a deliberately vulnerable Linux target used for practicing enumeration and exploitation techniques in an isolated lab environment. The exercise covers network reconnaissance, SMB share enumeration, anonymous file access, SSH foothold acquisition, and post-exploitation flag discovery.

Goals of the engagement:

- Identify open services and their versions through active network scanning.
- Enumerate Samba/NetBIOS shares for anonymously accessible files.
- Recover the first flag from an exposed SMB share.
- Establish an interactive SSH session using credentials discovered during enumeration.
- Locate and analyze suspicious scripts on the target, then recover the second flag.

2. Environment Summary

Hypervisor	VMware Workstation Pro
Attacker Host	Kali Linux 2026.1 (kernel 6.18.12+kali-amd64)
Target Hostname	WestWild / westwild
Target OS (per nmap)	Ubuntu 14.04.6 LTS (Linux kernel 3.2 – 4.14 range)
Target IP	192.168.190.131

3. Reconnaissance

3.1 Port Scanning (Nmap)

An aggressive service/version scan was run against the target to identify open ports and fingerprint running services:

```
nmap -A 192.168.190.131
```

```

kali@kali:~$ sudo nmap -sS 192.168.190.131
sudo: unable to resolve host kali: Name or service not known
[sudo] password for kali:
Nmap scan report for 192.168.190.131
Starting Nmap 7.00 ( https://nmap.org ) at 2026-06-27 04:31 -0400
Nmap scan report for 192.168.190.131
Host is up (0.0013 latency).
Not shown: 655 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2)
80/tcp    open  http           Apache/2.4.7 (Ubuntu)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
MAC Address: 08:0C:29:08:5F:9D (VMware)
Device type: general purpose
Running: Linux 3.X/4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 2 hops
Service Info: Host: WESTWILD; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-security-mode:
|   3.1.1
|   Message signing enabled but not required
|_ smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|   Computer name: westwild
|   NetBIOS computer name: WESTWILD\*
|   Domain name: _WORK_
|   FQDN: westwild
|   System time: 2026-06-27T11:32:38-03:00
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ clock-skew mean: 3h40m, deviation: 1h45m, median: 31s
|_ _stat: NetBIOS name: WESTWILD, NetBIOS user: unknown, NetBIOS MAC: unknown (unk
|_ smb2-time:
|   date: 2026-06-27T00:32:38
|   start_date: N/A
|_ TRACEROUTE
|_ hop: RTT: ADDRESS
|   1: 0.13 ms 192.168.190.131

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

```

Figure 1 — Nmap scan results showing SSH, HTTP, and Samba services on the WestWild target.

Key findings from the scan:

- **Port 22/tcp** — OpenSSH 6.6.1p1 (Ubuntu 2ubuntu2.13)
- **Port 80/tcp** — Apache httpd 2.4.7 (Ubuntu), no page title set
- **Ports 139/445 tcp** — Samba smbd (versions 3.X–4.X and 4.3.11-Ubuntu reported), workgroup WORKGROUP
- **NetBIOS / SMB info** — Computer name: westwild, guest access supported, message signing disabled (flagged by nmap as "dangerous, but default")

The combination of guest-accessible SMB shares and disabled message signing made Samba the most promising initial enumeration vector.

3.2 Samba/NetBIOS Enumeration (enum4linux)

The enum4linux wrapper script was invoked to plan further enumeration of users, shares, and password policy via RID cycling and SMB queries:

```
enum4linux
```

```

kali-linux-2026.1-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
x-2026.1-vmware-amd64
Session Actions Edit View Help
root@kali: /home/kali
root@kali: /home/kali
enum4linux v0.9.1 (http://labs.portcullis.co.uk/application/enum4linux/)
Copyright (C) 2011 Mark Lowe (info@portcullis-security.com)

Simple wrapper around the tools in the samba package to provide similar
functionality to enum.exe (formerly from www.hackplayers.com). Some additional
features such as RID cycling have also been added for convenience.

Usage: ./enum4linux.pl [options] ip

Options are (like "enum"):
-u      get userlist
-m      get machine list
-s      get sharelist
-p      get password policy information
-g      get group and member list
-d      be detailed, applies to -u and -s
-u user  specify username to use (default "")
-p pass  specify password to use (default "")

The following options from enum.exe aren't implemented: -l, -N, -D, -f

Additional options:
-a      Do all simple enumeration (-u -s -g -p -r -o -i).
        This option is enabled if you don't provide any other options.
-h      Display this help message and exit.
-r      enumerate users via RID cycling
-R range RID ranges to enumerate (default: 500-1000,1000-1050, implies -r)
-k n     Keep searching RIDs until n consecutive RIDs don't correspond to
        a username. Implies RID range ends at 999999. Useful
        against DCs.
-i      Get some (limited) info via LDAP 389/TCP (for DCs only)
-f file  Brute force guessing for share names
-u user  User(s) that exists on remote system (default: administrator,guest,krbtg
t,domain admin,root,admin)
        Used to get sid with "lookupsid kuuu_username"
-o combs Use combs to try several users: "-a admin,user,user2"
-o      Get OS information
-i      Get printer information
-w wkg   Specify workgroup manually (usually found automatically)
-n      Do an smblookup (similar to smbclient)
-v      Verbose. Shows full commands being run (net, rpcclient, etc.)
-a      Aggressive. Do write checks on shares etc

RID cycling should extract a list of users from Windows (or Samba) hosts
which have RestrictAnonymous set to 1 (Windows NT and 2000), or "Network
access: Allow anonymous SID/Name translation" enabled (XP, 2003).

NB! Samba servers often seem to have RIDs in the range 3000-3009.

Dependency info: You will need to have the samba package installed as this
script is basically just a wrapper around rpcclient, net, smblookup and
smbclient. Polenum from http://labs.portcullis.co.uk/application/polenum/
is required to get Password Policy info.

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.
29°C Partly sunny
Search
ENG IN 02:22 PM 27-05-2026

```

Figure 2 — enum4linux usage/help output, used to plan share and user enumeration against the target.

This confirmed the available enumeration options (share listing, user listing via RID cycling, password policy, and OS info) before targeting the SMB service directly with smbclient.

4. Initial Access via SMB

4.1 Anonymous SMB Login & FLAG1 Retrieval

Given that guest/anonymous SMB access was available, smbclient was used to connect directly to a share named "wave" on the target without credentials:

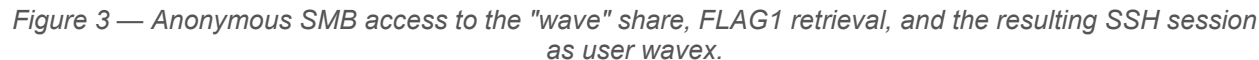
```
smbclient //192.168.190.131/wave
```

The anonymous login succeeded immediately, exposing two files of interest:

- FLAG1.txt (93 bytes)
- message_from_aveng.txt (115 bytes)

Both files were retrieved using the SMB get command and read locally:

```
smb: \> get FLAG1.txt
cat FLAG1.txt
```



4.2 SSH Foothold

```
ssh wavex@192.168.190.131
```

```
find / -writable-type d 2>/dev/null
cd /usr/share/av/websitesecret
ls
```

Page 5 of 8

5. Post-Exploitation: Script Analysis & FLAG2

The suspicious script was inspected, removed, and recreated/edited during the session (consistent with a player examining its contents and then clearing the directory), after which a second flag file was located directly in the home directory:

```
cd /usr/share/av/westsidesecret
vim ififoregt.sh
rm ififoregt.sh
vim ififoregt.sh
cd
vim FLAG2.txt
cat FLAG2.txt
```

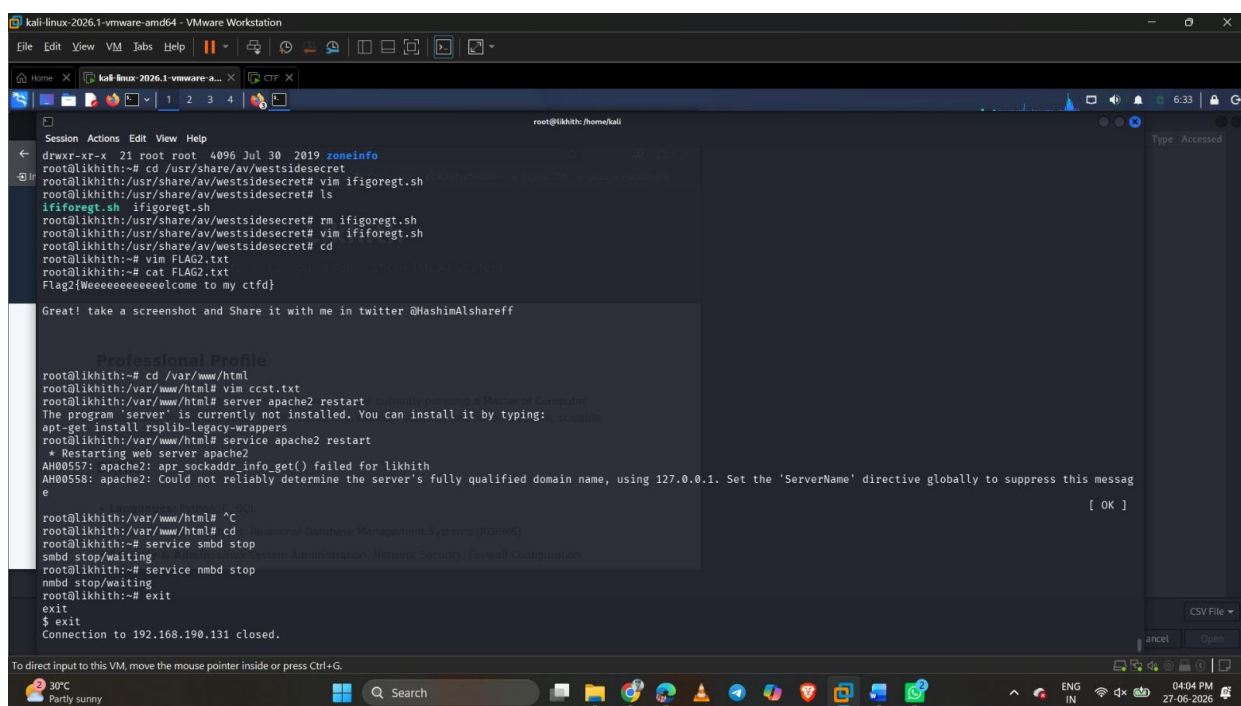


Figure 4 — Reviewing the planted script in `/usr/share/av/westsidesecret`, recovering `FLAG2`, and cleanup of web/SMB services.

FLAG2.txt contained a themed greeting string (see Section 6) along with an in-challenge message directing players to take a screenshot and share it on social media — a typical "proof of completion" prompt embedded by the CTF author, included here for completeness but not treated as a serious instruction.

Following flag capture, the session also touched `/var/www/html` (editing a `ccst.txt` file and attempting an Apache restart) before the engagement was wound down by stopping the `smbd` and `nmbd` services and closing the SSH connection — standard session cleanup rather than part of the core exploitation path.

6. Flags Captured

Flag	Source / Method	Value
FLAG1	Anonymous SMB share "wave" (smbclient, guest login)	RmxhZzF7V2VsY29tZV9UMF9USEUtVzNTVC1XMUxELUIwcmRlcn0KdXNlcjp3YXZleApwYXNzd29yZD9wZW4K
FLAG2	Home directory of wavex after reviewing /usr/share/av/websitesecret	Flag2{Weeeeeeeeeeeeeel come to my ctf d}

FLAG1 is Base64-encoded. Decoding it locally confirms it is well-formed and reveals the following plaintext, which also doubles as the credential hint used for the SSH foothold in Section 4.2:

```
Flag1{Welcome_T0_THE-W3ST-W1LD-B0rder}  
user:wavex  
password?pen
```

7. Summary of Attack Path

- Nmap identified SSH, HTTP, and Samba (ports 139/445) open on the target, with guest SMB access permitted.
- enum4linux was used to scope out further SMB/NetBIOS enumeration options.
- smbclient anonymous login to the "wave" share exposed FLAG1.txt directly, with no authentication required.
- Decoding FLAG1 (Base64) revealed both a username and password hint, allowing an SSH foothold as user wavex.
- A writable-path sweep uncovered a suspicious script planted in a fake antivirus directory.
- Reviewing that location led to FLAG2, completing the exercise.

8. Lessons & Hardening Notes

From a defensive standpoint, this exercise highlights several common misconfigurations worth flagging in a real environment:

- Guest/anonymous SMB access should be disabled unless explicitly required, and shares should never host sensitive files without authentication.
- SMB message signing should be enforced (not just enabled-but-not-required) to reduce relay attack exposure.
- Files or scripts placed in misleadingly named system paths (e.g. a fake /usr/share/av directory) are a reminder to audit non-standard directories under shared system paths.
- Service cleanup (disabling smbd/nmbd when not needed) reduces the attack surface significantly, as demonstrated in the session teardown.

9. Conclusion

The WestWild boot2root exercise demonstrates a realistic, low-friction attack chain: an exposed SMB share with anonymous access yielded both an initial flag and, once decoded, the credentials needed to pivot into an authenticated SSH session, after which a planted script in a disguised directory led to the second flag. The walkthrough reinforces the value of systematic enumeration — checking every open port and service, including ones that seem secondary to the main web/SSH targets — before attempting exploitation.